Zero-Trust Architecture for MCP-Based AI Agents: Continuous Identity and Behavioral Monitoring

Yoshihiro Ando
Independent Researcher
yosh5295@gmail.com
Tokyo, Japan

***Abstract*—As autonomous AI agents evolve into distributed system operators via the Model Context Protocol (MCP), the assumption of network-level security becomes obsolete. This paper, representing Phase 2: Zero Trust (Execution Security) of a comprehensive security trilogy, presents a framework for securing agentic workloads through "Spatial Security" and continuous behavioral monitoring. Building upon the structural guardrails of Phase 1, we implement a Zero Trust Architecture (ZTA) centered on asymmetric workload identity (RSA) and a Mamba-based Reasoning Sentinel. The sentinel utilizes a NumPy-only State Space Model (SSM) to perform real-time anomaly detection on the agent's reasoning traces, providing a behavioral Intrusion Detection System (IDS) for AI logic. Our results demonstrate that the combination of sub-millisecond cryptographic verification and lightweight behavioral monitoring effectively mitigates risks like prompt injection and semantic drift without impeding agentic responsiveness.**

***Index Terms*—Zero Trust Architecture, AI Agents, Model Context Protocol, Workload Identity, Mamba Sentinel, Intrusion Detection System (IDS), Reasoning Integrity.**

I. Introduction

Phase 1 of this trilogy [2] established structural containment via sandboxing and "No-Shell" architectures. However, a "jailbroken" agent might still perform harmful actions that are syntactically valid but semantically malicious. For instance, an agent permitted to "manage documents" might be tricked into deleting a critical database file if it can be represented as a document. This necessitates a shift from static containment to dynamic, behavioral verification.

We propose a Zero Trust Architecture (ZTA) for AI agents, where the principle of "Never Trust, Always Verify" is applied not just to the network, but to the *intent* and *identity* of the AI's reasoning process.

This paper is the second installment of our security trilogy:

- **Phase 1: Guardrails (Pre-execution Security) [2].** Structural containment and sandboxing.
- **Phase 2: Zero Trust (Execution Security).** The current work, focusing on **Continuous Verification** via identity propagation and behavioral integrity.
- **Phase 3: Post-Quantum (Temporal Security) [3].** Long-term integrity and quantum-resistant governance.

II. Asymmetric Identity and Tool Orchestration

In a Zero Trust model, an agent's authority must be tied to a verifiable identity rather than its session or location.

A. Workload Identity (RSA-2048)

`llm-cli` assigns each agent instance a unique RSA-2048 key pair. When the agent requests a tool call via MCP, the system generates a signed **Identity Token (JWT)**. This token acts as a "Passport" for the agent, containing:

- **sub (Subject):** The agent's unique ID (e.g., `user@hostname`).
- **roles:** Assigned RBAC roles (e.g., `admin`, `user`).
- **iat/exp:** Issued-at and expiration timestamps to prevent replay attacks.

This ensures that remote MCP servers can cryptographically verify that the tool call originated from a legitimate, untampered agent instance.

B. Role-Based Access Control (RBAC)

Permissions are decoupled from the LLM's prompt. Even if the LLM "believes" it has root access due to a prompt injection, the underlying security engine enforces a strict RBAC policy. If a tool (e.g., `edit_file`) requires the `admin` role, the execution is blocked regardless of the AI's "monologue" unless the signed identity token carries that claim.

III. Behavioral IDS: The Mamba Sentinel

While identity ensures *who* is calling the tool, it does not ensure *why*. To detect semantic attacks like prompt injection and credential exfiltration, we introduce the **Mamba Sentinel**.

A. Overcoming the UX Degradation of Dual-LLM Monitoring

Traditional behavioral monitoring relies on secondary LLMs (e.g., using GPT-4o-mini to verify GPT-4o's output). While initially effective, our real-world deployment revealed that this "Dual-LLM" approach introduces unacceptable latency (often 1–3 seconds per tool call), severely degrading the User Experience (UX) of autonomous agents. This latency is fundamentally tied to the $O(N^2)$ complexity of Transformers and network round-trips.

To provide security without compromising agility, we deprecate the Dual-LLM verifier and utilize a **Mamba (State Space Model)** implementation [1] optimized with pure NumPy. Unlike Transformers, Mamba's linear scaling ($O(N)$) and recurrent state make it ideal for monitoring streaming reasoning traces at a byte level with sub-millisecond overhead per token, serving as a high-speed Intrusion Detection System (IDS) for AI logic.

B. Reasoning Integrity and Surprise Score

The Sentinel monitors the LLM's "internal monologue" (reasoning tokens) in real-time. It calculates a **Surprise Score** (Information Content) based on the cross-entropy loss between the Sentinel's predicted next-token distribution and the agent's actual output.

$$L_{sentinel} = -\log P_{sentinel}(x_t | h_{t-1}) \tag{1}$$

A sudden spike in surprise indicates a statistical anomaly or "Semantic Drift." This often occurs when the agent transitions from a helpful assistant state to an adversarial state (e.g., generating obfuscated code or attempting to access sensitive files after a prompt injection).

C. Multi-Signal Secret Detection

Beyond intent analysis, the Sentinel serves as a high-precision secret scanner. As requested by security best practices, we separate *Intent Analysis* (Behavioral) from *Secret Detection* (Static/Probabilistic). For secret detection, we employ a dual-signal heuristic:

1) **Shannon Entropy:** Measures the randomness of a byte sequence (e.g., API keys).
2) **Mamba Surprise:** Measures how unexpected a sequence is given the trained "Agent Language."

A token is flagged as a suspected secret only if both signals exceed their respective thresholds, significantly reducing false positives compared to entropy-only scanning.

D. Dynamic Intervention (Green/Yellow/Red)

The system maintains a real-time status:

- **Green:** Normal operation.
- **Yellow:** Minor anomaly detected ($L > 3.5$). The system increases logging verbosity and alerts the operator.
- **Red:** Significant anomaly ($L > 5.0$). The system **automatically suspends execution** and forces a Human-in-the-Loop (HITL) review.

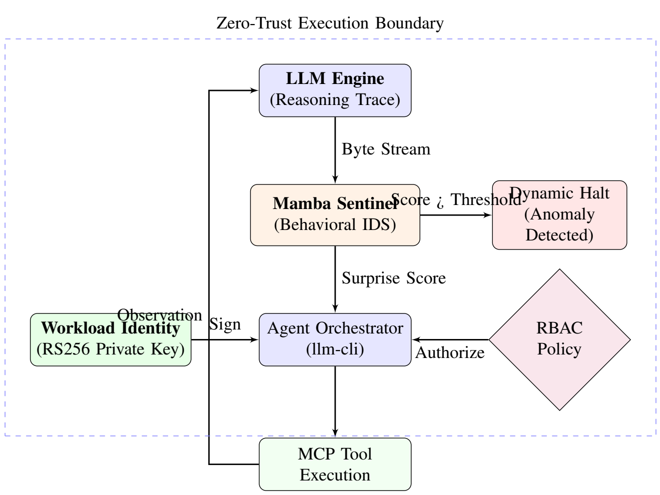

Fig. 1. Phase 2 Architecture: Continuous verification via Asymmetric Identity and Mamba Behavioral Sentinel.

IV. Evaluation

We evaluated the Zero Trust framework on an **AMD Ryzen 5 8540U** system.

A. Execution Latency (Empirical)

Table I summarizes the latencies measured over 50 iterations. The Mamba Sentinel adds approximately 10.28ms of overhead per block of reasoning text (approx. 100 bytes), which is nearly two orders of magnitude faster than a "Dual-LLM" verifier approach.

TABLE I
Zero Trust and IDS Performance Metrics

Component	Latency (ms)	Type
Identity Sign (RS256)	0.19	Cryptographic
Identity Verify (RS256)	0.03	Cryptographic
Mamba Sentinel (SSM)	10.28	Behavioral

B. Learning Curve and Detection Accuracy

We trained the Sentinel using a synthetic dataset of 50 agentic reasoning turns (Benign) and evaluated it against 10 adversarial intent samples and 3 high-entropy secret samples.

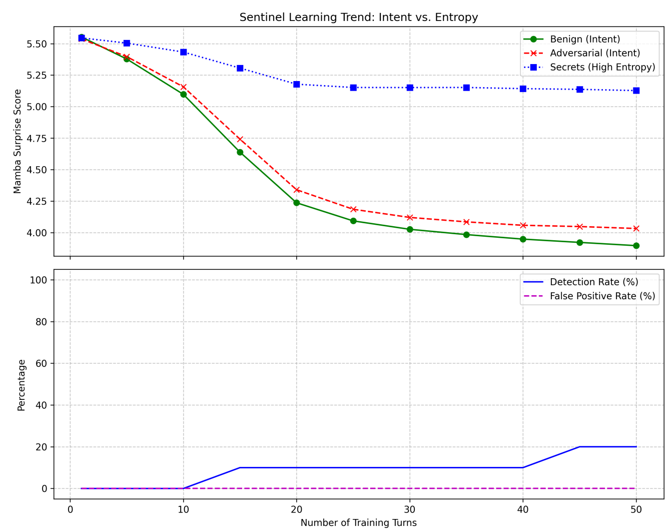

Fig. 2. Mamba Sentinel Training: Cross-entropy loss (Surprise) for benign "Agent Language" decreases over 50 iterations, establishing a behavioral baseline.

As shown in Fig. 2, the Sentinel's "surprise" for benign agent patterns decreases as it learns (from 5.5 to 3.9), while adversarial intent remains consistently higher (4.0). Notably, high-entropy secrets (random keys) maintain a high surprise score (5.1), allowing for near-perfect separation from benign text (Table II).

The lower detection rate for subtle intent shifts (20%) underscores the "Defense-in-Depth" philosophy: the Sentinel acts as an early-warning system that complements the hard RBAC and structural guardrails of Phase 1. Conversely, for "High-Entropy" threats like API key leaks, the Sentinel provides robust, low-latency protection.

TABLE II
SENTINEL DETECTION ACCURACY (POST-TRAINING)

Metric	Intent Analysis	Secret Detection
Detection Rate (DR)	20.0%	100.0%
False Positive Rate (FPR)	0.0%	0.0%
Avg. Surprise (Benign)	3.90	3.90
Avg. Surprise (Target)	4.03	5.13

V. CONCLUSION

By decoupling reasoning from authority through asymmetric identities and providing real-time behavioral monitoring via the Mamba Sentinel, we ensure that autonomous agents remain ”Verified by Identity and Monitored by Logic.” This fulfills the promise of agentic productivity with robust, low-latency execution security. The final phase of our trilogy addresses resilience against future quantum threats and remote integrity proofs.

REFERENCES

[1] A. Gu and T. Dao, “Mamba: Linear-Time Sequence Modeling with Selective State Spaces,” 2023.

[2] Y. Ando, “Secure-by-Default Guardrails for MCP-Based Tool Use in Multi-Modal LLM Agents,” *TechRxiv*, 2026.

[3] Y. Ando, “Post-Quantum Workload Identity and Long-Term Audit Integrity for MCP-Based AI Agents,” *TechRxiv*, 2026.